

Case 4

Cyber Security Incident Response

Group 15

Ammar Shareiyat

Khalil al-Towhi

Ankit Gautam

Hasan, Mohammad Kamrul

1. How would you classify the incident? Define in a few sentences.

From the described scenario, it is not clear to achieve a specific classification for the incident.

According to an investigation by IRT (incident response team):

- File transferred originated from an authorised account that belongs to one of the employees at the financial department that has access to all registered accounts.
- File transfers of several instances were started during non-working hours from remote locations using SSH protocol.

From this evidences, mainly two questions will arrive and that are:

1. Is it an insider job or outsider job?
2. What is the policy for financial department employees about non-working hours and what kind of files they can deal with?

To answer question 1, the suspected employee should have been called by IRT to clarify during the investigation. If the financial department employee (he or she) recognised, then questions 2 would arise. If he or she is authorised to transfer files during non-working hours according to company policy, then we can ignore the incident and consider it as not adverse events.

However, there is still an opportunity to mislead the privilege because after midnight (At 03.43 AM), the incident happened. Further investigation was needed to identify this, such as what kind of file he or she transfers and what purpose? If it violates the company policy, law, or unacceptable act then we can consider the incident as an information security incident and classify it as a High-Level Incident.

On the other hand, if the employee refused to agree to this incident, it will be considered a deliberate security incident (Brute Force or masquerade) using the employee's credentials which can be classified as a High-Level Incident due to its impact. Attackers can transfer all of the registered customer credentials, such as personally identifiable information and payment card information.

Moreover, SSH protocol is basically used in an organization for remote command execution such as file transfer using a CSP command or login over an unsecured network. it can be a valuable attack vector for

hackers. One of the most reliable ways to gain SSH access to servers is by brute-forcing credentials. Users are normally authorized to use **SSH** public key authentication so if users are careless handling of their private keys (i.e placing them in insecure locations, copying them to multiple computers, and not protecting them with strong passwords) then it can be an adverse event or information security incident for an organisation.

2. How would you assess and resolve the incident? Describe the steps (in accordance with the incident management process presented in the lecture) and actions taken.

To assess and resolve the incident we follow the incident response life cycle from “Incident Handling Guide - NIST-SP800-61r2”.

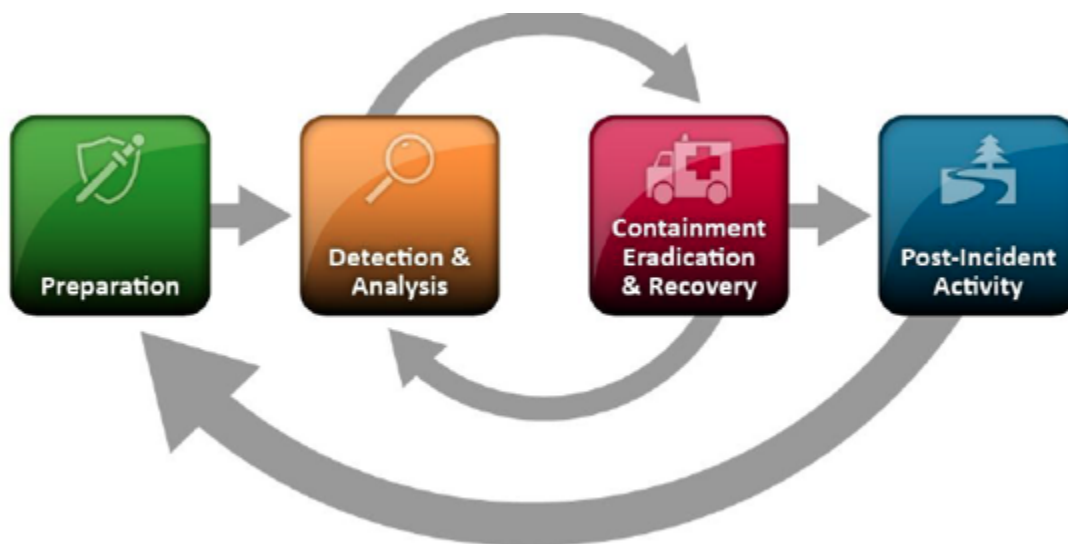


Figure 3-1. Incident Response Life Cycle

The incident response process has several major phases of the incident response process:

- Preparation,
- Detection and analysis,
- Containment, eradication and recovery, and
- Post-incident activity

Preparation, and detection and analysis has already been done by an automated system (we assumed because there is no clear idea from the scenario who sent the notification) sending a notification to the incident response manager of Casino 10-4 and an assessment and analysis (based on logs) given by IRT. The incident was occurred

Incident Analysis

- The incident occurred in database back end servers in the internal network and an automated system (assumed) discovered it (At 03.43) by high usage of CPU power on one of the database backend servers that reside on a Solaris machine .
- A remote command execution such as file transfer using a CSP command (/bin/scp using SSH).
- The financial department employee credentials have been compromised by the incident (if outsider job Q1) and all registered account's credentials.
- The scope of impact could be lost confidentiality and integrity and severity of incident could be high for Casino 10-4.

Incident Prioritization

If the suspected employee refused to agree to this incident, a deliberate security incident (Brute Force or masquerade) can be classified as a High-Level Incident due to its impact and it may result in the exfiltration of personally identifiable information (PII), which could have a long-lasting impact on the organization's reputation. So appropriate action should take immediately such as temporarily suspending the suspected employee and notify the register account to change their user ID and password.

If the suspected employee violates the company policy, law, or unacceptable act then we can consider the incident as an information security incident and classify it as a High-Level Incident. In this case immediate action should be taken according to the company's rule and resolution.

Incident Notification

After an incident is analyzed and prioritized, IRT should send a report to the appropriate individuals so that all who need to be involved will play their roles. The entity that is typically reported to CIO, Head of information security, Local information security officer, Other incident response teams within the organization and so forth through appropriate communication methods.

Containment, Eradication, and Recovery

Containment

Contain the security incident to prevent the damage to be occurred, we can perform the actions below:

- As a short-term containment, Isolate the server that has been observed by high usage of CPU power.
- As a system-backup, we need to prepare forensic copies of the affected backend server to be used for analysis, and also store those in a secure location.
- As a Long-term containment, in case there is possibility to turn the DB server off, then we can continue for the eradication step after turning it off.
- The suspected employee should be suspended during investigation periods.
- Monitoring the SSH channel that is used by the suspected employee.

Eradication

After the containment step, the eradication step will be more efficient. We can consider the items below to eradicate the security incident:

- Review the security controls and ACL within the security policy to determine whether the access to the company property is acceptable and doable during non-working hours or not.
- Ensure that we have defined the clear policies and the system cannot be compromised another time.
- Ensure that all the servers data and also the employees laptop are encrypting the data.
- Try to harden the server with patches weekly/monthly.
- Specify the access to the server by using SSH to be from a certain source or department , user or even during specific times.

Recovery

- After the previous steps, once we are done with containing and eradication, it is required to probably disable the used channel for suspected attack, or even a temporary disabling for suspected employee.
- The system administrator notify the registered customer (if an employee or masquerade collects their credentials) to change their ID, password and credit card information.
- The system administrator should ensure that the system is functioning as it is expected.

3. Identify and propose post-incident actions.

Post-Incident actions have a high importance within the incident response, since with these actions we can learn and improve the IRT and our organization. The relevant teams should be engaged and gather information and lessons from the recent incident to know the similar threats and determine the vulnerabilities, and improve the technologies and our security controls accordingly to prevent or mitigate the threats. For the mentioned reasons we need to hold a “lessons learned” meeting and invite all stakeholders and departments that are involved after a certain incident.

We can ask several questions related to the incident or take the actions as below:

- Elaborate what occurred precisely with as much as details?
- How did the responsible teams handle the incident? And what was the document or procedures that they followed accordingly?
- What are the actions that the responsible team should do the same or similar for the next equivalent incident?

- What are the actions that they have not to do for the next similar incident?
- What kind of technology , resources improvement the organization needs to prevent the occurrence of such an incident?
- Identify the lessons learnt from the recent incidents and vulnerabilities.
- Review the incident response process of the incident that had occurred.
- In internal point of view , the system can consider more elaboration and education for the operational and security IT departments and employees.

Test and exercise the incident management plan:

We can have a plan to perform an exercise to validate, train and test by simulating a similar security incident.

Using collected Incident Data

We meant by collecting incident data that by holding the lessons learned meeting we need to wrap up with a set of useful data relevant to the incident. For instance, how many hours and the time cost and objective assessment of the incident during the handling of the security incident. By collecting the useful data we can propose the security weaknesses and threats and then improve our risk assessment process and eventually implement additional security controls that lead to protect the organization as much as possible.

Eventually, all the collected data should be retained according to the agreed data retention policy of the organization.